Networking Fundamentals: A Comprehensive Guide

This document covers essential networking concepts including IP addressing, subnetting, transport protocols, and common ports targeted by attackers.

1. What is a Network?

A network is a collection of interconnected devices (computers, servers, smartphones, printers, etc.) that can communicate and share resources with each other. Networks can range from small local connections to the global internet.

Types of Networks:

· LAN (Local Area Network): A network confined to a small geographic area such as a home, office, or school building.

· WAN (Wide Area Network): A network that spans a large geographic area, often connecting multiple LANs. The internet is the largest WAN.

· MAN (Metropolitan Area Network): A network that spans a city or large campus.

· PAN (Personal Area Network): A small network centered around an individual, such as Bluetooth connections between a phone and laptop.

Networks use protocols (rules) to govern how data is formatted, addressed, transmitted, and received

2. IP Address: Detailed Explanation

An IP address (Internet Protocol address) is a unique numerical identifier assigned to every device connected to a network. It serves two primary functions:

1. Host Identification: It identifies the device on the network.

2. Location Addressing: It provides the location of the device so data can be routed to it.

IP addresses are like postal addresses. Just as a postal address tells the mail carrier where to deliver a letter, an IP address tells network routers where to deliver data packets.

Versions of IP Addresses

IPv4 (Internet Protocol version 4):

· Uses 32-bit addresses.

· Represented in dotted decimal format: four numbers separated by periods, each ranging from

0 to 255.

· Example: 192.168.1.1

· Total possible addresses: approximately 4.3 billion.

· Due to exhaustion of IPv4 addresses, IPv6 was introduced.

IPv6 (Internet Protocol version 6):

· Uses 128-bit addresses.

· Represented in hexadecimal format: eight groups of four hexadecimal digits separated by colons.

· Example: 2001:0db8:85a3:0000:0000:8a2e:0370:7334

· Total possible addresses: approximately 340 undecillion (virtually unlimited).

Structure of an IPv4 Address

An IPv4 address consists of two parts:

1. Network Portion: Identifies the specific network the device belongs to.

2. Host Portion: Identifies the specific device on that network.

The division between network and host portions is determined by the subnet mask

3. IP Address Classes

IP addresses were originally divided into classes to accommodate networks of different sizes. This system is known as classful addressing. While classless addressing (CIDR) is now the standard, understanding classes is still important for historical context and foundational knowledge.

Class Leading Bits Range (First Octet) Network Portion Host Portion Default Subnet Mask Purpose

Class A 0 1 - 126 First octet Last three octets 255.0.0.0 Very large networks (few networks, many hosts per network)

Class B 10 128 - 191 First two octets Last two octets 255.255.0.0 Medium-sized networks (e.g., universities, large companies)

Class C 110 192 - 223 First three octets Last octet 255.255.255.0 Small networks (e.g., small businesses, home networks)

Class D 1110 224 - 239 N/A N/A N/A Multicast (one-to-many communication, not assigned to

hosts)

Class E 1111 240 - 255 N/A N/A N/A Experimental and research purposes

Special IP Address Ranges:

· Loopback Address: 127.0.0.0 to 127.255.255.255 (commonly 127.0.0.1). Used for testing and internal communication on the local device.

· Private IP Addresses (Non-routable on the internet):

  · Class A Private: 10.0.0.0 to 10.255.255.255

  · Class B Private: 172.16.0.0 to 172.31.255.255

  · Class C Private: 192.168.0.0 to 192.168.255.255

· APIPA (Automatic Private IP Addressing): 169.254.0.0 to 169.254.255.255. Assigned automatically when a device cannot reach a DHCP server.

· Public IP Addresses: All addresses not reserved for private or special use. These are routable on the internet.

4. Subnet Mask

A subnet mask is a 32-bit number that separates the IP address into network and host portions. It tells network devices which part of the IP address identifies the network and which part identifies the specific device.

How Subnet Masks Work

A subnet mask consists of a sequence of binary 1s followed by binary 0s. The 1s represent the network portion, and the 0s represent the host portion.

Example with IP 192.168.1.100 and Subnet Mask 255.255.255.0:

· Binary representation of mask: 11111111.11111111.11111111.00000000

· The first 24 bits are 1s (network portion)

· The last 8 bits are 0s (host portion)

Result:

· Network Address: 192.168.1.0 (all host bits set to 0)

· Broadcast Address: 192.168.1.255 (all host bits set to 1)

· Usable Hosts: 192.168.1.1 to 192.168.1.254 (254 usable addresses)

CIDR Notation (Classless Inter-Domain Routing)

Modern networking uses CIDR notation instead of classful addressing. CIDR allows for flexible subnet sizes by specifying the number of bits used for the network portion.

Format: IP_Address/Prefix_Length

Examples:

· /24 means 24 bits for network (equivalent to 255.255.255.0)

· /16 means 16 bits for network (equivalent to 255.255.0.0)

· /8 means 8 bits for network (equivalent to 255.0.0.0)

Common CIDR Prefixes:

CIDR Subnet Mask Total IPs Usable IPs Use Case

/32 255.255.255.255 1 1 Single host (loopback, point-to-point)

/30 255.255.255.252 4 2 Point-to-point links (router connections)

/29 255.255.255.248 8 6 Small workgroups

/28 255.255.255.240 16 14 Small networks

/27 255.255.255.224 32 30 Medium-sized networks

/26 255.255.255.192 64 62 Larger workgroups

/25 255.255.255.128 128 126 Medium departments

/24 255.255.255.0 256 254 Standard small network

/23 255.255.254.0 512 510 Larger networks

/22 255.255.252.0 1024 1022 Campus networks

/16 255.255.0.0 65536 65534 Large organizations

/8 255.0.0.0 16777216 16777214 Very large networks

---

5. TCP (Transmission Control Protocol)

TCP is a connection-oriented transport layer protocol that provides reliable, ordered, and error-checked delivery of data between applications.

Key Characteristics

· Connection-Oriented: A three-way handshake (SYN, SYN-ACK, ACK) establishes a connection before data transfer begins.

· Reliable: Uses acknowledgments (ACKs) to confirm receipt of data. If an acknowledgment is not received, the data is retransmitted.

· Ordered: Segments are numbered so they can be reassembled in the correct order even if they arrive out of sequence.

· Flow Control: Uses windowing to prevent the sender from overwhelming the receiver with too much data at once.

· Error Checking: Includes a checksum in each segment to detect corruption.

· Heavy Overhead: Larger header size (20 bytes minimum) and more processing overhead compared to UDP.

TCP Three-Way Handshake

1. SYN: The client sends a segment with the SYN flag set, indicating a request to establish a connection. It includes an initial sequence number.

2. SYN-ACK: The server responds with a segment that has both SYN and ACK flags set, acknowledging the client's sequence number and sending its own initial sequence number.

3. ACK: The client sends an ACK segment to acknowledge the server's sequence number. The connection is now established.

TCP Header Structure (20-60 bytes)

· Source Port (16 bits)

· Destination Port (16 bits)

· Sequence Number (32 bits)

· Acknowledgment Number (32 bits)

· Data Offset (4 bits)

· Flags (9 bits): SYN, ACK, FIN, RST, PSH, URG, etc.

· Window Size (16 bits)

· Checksum (16 bits)

· Urgent Pointer (16 bits)

· Options (0-40 bytes)

6. UDP (User Datagram Protocol)

UDP is a connectionless transport layer protocol that provides fast, lightweight data transmission without guarantees of reliability or order.

Key Characteristics

· Connectionless: No handshake required. Data is sent without establishing a connection.

· Unreliable: No acknowledgments or retransmissions. Packets may be lost, duplicated, or arrive out of order.

· No Flow Control: Sender transmits at whatever rate it chooses, potentially overwhelming the receiver.

· Low Overhead: Small header size (8 bytes) and minimal processing overhead.

· Faster: Lower latency than TCP, making it ideal for real-time applications.

UDP Header Structure (8 bytes)

· Source Port (16 bits)

· Destination Port (16 bits)

· Length (16 bits)

· Checksum (16 bits)

When to Use TCP vs UDP

Scenario Protocol Reason

Web browsing (HTTP/HTTPS) TCP Reliability is critical. Missing data would break web pages.

Email (SMTP, IMAP, POP3) TCP Email must be delivered completely and in order.

File transfer (FTP, SFTP) TCP File integrity requires reliable delivery.

Remote access (SSH) TCP Command execution requires ordered, reliable data.

Database connections TCP Data consistency requires reliability.

Voice over IP (VoIP) UDP Speed matters more than occasional lost packets.

Video streaming UDP Dropped frames are acceptable; delays are not.

Online gaming UDP Low latency is critical; occasional packet loss is tolerable.

DNS queries UDP Small, quick queries; retries handle lost packets.

DHCP UDP Broadcast-based; connection overhead would be wasteful.

7. Top 30 Ports Commonly Exposed and Targeted for Hacking

Ports are virtual endpoints that allow different applications and services to communicate over a network. Each port number is associated with a specific protocol (TCP or UDP) and often with a specific service.

Attackers commonly scan for open ports to identify running services that may have vulnerabilities, misconfigurations, or weak credentials. Below are the top 30 ports frequently targeted.

Port 21: FTP (File Transfer Protocol)

· Protocol: TCP

· Service: File Transfer Protocol

· Common Attacks: Anonymous login vulnerabilities, brute force attacks, plaintext credentials sniffing, FTP bounce attacks.

· Why Targeted: Often misconfigured to allow anonymous access or weak passwords. Transmits credentials in plain text.

Port 22: SSH (Secure Shell)

· Protocol: TCP

· Service: Secure Shell (remote administration)

· Common Attacks: Brute force password attacks, credential stuffing, vulnerability exploitation (e.g., CVE-2024-6387 OpenSSH signal handler race condition), key theft.

· Why Targeted: Provides direct shell access to systems. Compromising SSH often means full system compromise.

Port 23: Telnet

· Protocol: TCP

· Service: Telnet (remote administration)

· Common Attacks: Credential sniffing (plain text), brute force attacks, session hijacking.

· Why Targeted: Transmits all data including credentials in plain text. Should never be exposed to untrusted networks.

Port 25: SMTP (Simple Mail Transfer Protocol)

· Protocol: TCP

· Service: Email sending

· Common Attacks: Email spoofing, open relay abuse for spam, phishing campaigns, mail server compromise.

· Why Targeted: Open SMTP relays allow attackers to send spam anonymously. Mail servers often contain sensitive data.

Port 53: DNS (Domain Name System)

· Protocol: TCP and UDP

· Service: Domain name resolution

· Common Attacks: DNS amplification DDoS attacks, DNS spoofing (cache poisoning), DNS tunneling for data exfiltration, zone transfer leaks.

· Why Targeted: DNS servers are often used in reflection attacks. Misconfigured servers can leak internal network information.

Port 69: TFTP (Trivial File Transfer Protocol)

· Protocol: UDP

· Service: Trivial File Transfer Protocol

· Common Attacks: Unauthorized file access, configuration file theft, denial of service.

· Why Targeted: Often lacks authentication entirely. Commonly used by network devices to store configuration files.

Port 80: HTTP (Hypertext Transfer Protocol)

· Protocol: TCP

· Service: Web traffic (unencrypted)

· Common Attacks: Web application attacks (SQL injection, XSS), directory traversal, insecure direct object references, HTTP request smuggling.

· Why Targeted: The most common service exposed on the internet. Legacy systems and misconfigurations are abundant.

Port 110: POP3 (Post Office Protocol version 3)

· Protocol: TCP

· Service: Email retrieval

· Common Attacks: Credential brute forcing, plaintext credential sniffing (if SSL/TLS not enforced), mailbox compromise.

· Why Targeted: Often uses weak authentication. Can provide access to sensitive email communications.

Port 111: RPC (Remote Procedure Call) / Portmapper

· Protocol: TCP and UDP

· Service: Remote Procedure Call port mapping

· Common Attacks: Information disclosure (enumerating available RPC services), NFS attacks, privilege escalation, denial of service.

· Why Targeted: Reveals information about other services running on the system. Often associated with NFS vulnerabilities.

Port 135: RPC (Windows RPC)

· Protocol: TCP and UDP

· Service: Windows Remote Procedure Call

· Common Attacks: Information disclosure, DCOM exploits (e.g., EternalBlue precursor), denial of service.

· Why Targeted: Historically associated with many critical Windows vulnerabilities. Used in worm propagation.

Port 139: NetBIOS (NetBIOS Session Service)

· Protocol: TCP and UDP

· Service: NetBIOS over TCP/IP

· Common Attacks: SMB relay attacks, null session enumeration (Windows 2000/XP era), information disclosure, NTLM hash capture.

· Why Targeted: Legacy protocol that can leak user lists, shares, and other sensitive information.

Port 143: IMAP (Internet Message Access Protocol)

· Protocol: TCP

· Service: Email retrieval and management

· Common Attacks: Credential brute forcing, mailbox compromise, command injection vulnerabilities.

· Why Targeted: More feature-rich than POP3, often stores emails server-side. Compromise provides persistent email access.

Port 161: SNMP (Simple Network Management Protocol)

· Protocol: UDP

· Service: Network device monitoring

· Common Attacks: Community string brute forcing (public/private), information disclosure, device configuration modification, denial of service.

· Why Targeted: Default community strings (public, private) are widely known. Can reveal extensive network topology and configuration details.

Port 443: HTTPS (HTTP Secure)

· Protocol: TCP

· Service: Encrypted web traffic

· Common Attacks: Web application vulnerabilities (SQL injection, XSS, CSRF), SSL/TLS vulnerabilities (POODLE, Heartbleed), phishing sites.

· Why Targeted: The primary entry point for web applications. Despite encryption, application-layer vulnerabilities remain.

Port 445: SMB (Server Message Block)

· Protocol: TCP

· Service: Windows file and printer sharing

· Common Attacks: EternalBlue exploit (WannaCry/NotPetya), SMB relay attacks, NTLM hash capture, ransomware propagation, pass-the-hash attacks.

· Why Targeted: Historically one of the most exploited services on Windows. Critical vulnerabilities have led to widespread worms and ransomware.

Port 465: SMTPS (SMTP over SSL)

· Protocol: TCP

· Service: Encrypted email sending

· Common Attacks: Authentication bypass, credential brute forcing, email spoofing, spam relay abuse.

· Why Targeted: Secure version of SMTP but still subject to authentication attacks.

Port 993: IMAPS (IMAP over SSL)

· Protocol: TCP

· Service: Encrypted email retrieval

· Common Attacks: Credential brute forcing, mailbox compromise, authentication bypass vulnerabilities.

· Why Targeted: Encrypted but still vulnerable to credential-based attacks.

Port 995: POP3S (POP3 over SSL)

· Protocol: TCP

· Service: Encrypted email retrieval

· Common Attacks: Credential brute forcing, mailbox compromise.

· Why Targeted: Similar to IMAPS, encrypted but authentication remains the weak point.

Port 1433: MSSQL (Microsoft SQL Server)

· Protocol: TCP

· Service: Microsoft SQL Server database

· Common Attacks: Brute force attacks, SQL injection (via web apps), default credential exploitation (sa with blank password), remote code execution vulnerabilities.

· Why Targeted: Databases contain sensitive data. Default installations often have weak or default credentials.

Port 1521: Oracle SQL

· Protocol: TCP

· Service: Oracle Database

· Common Attacks: Default credential exploitation (system/manager), TNS listener vulnerabilities, SQL injection, brute force attacks.

· Why Targeted: Oracle databases store critical enterprise data. Misconfigurations are common.

Port 2049: NFS (Network File System)

· Protocol: TCP and UDP

· Service: Network file sharing (Unix/Linux)

· Common Attacks: Improper export configuration leading to unauthorized access, file system traversal, data theft.

· Why Targeted: Misconfigured NFS exports can expose entire file systems to unauthorized users.

Port 3306: MySQL

· Protocol: TCP

· Service: MySQL database

· Common Attacks: Brute force attacks, SQL injection (via web apps), default credential exploitation (root with blank password), remote code execution vulnerabilities.

· Why Targeted: Extremely common open-source database. Frequently exposed by misconfiguration.

Port 3389: RDP (Remote Desktop Protocol)

· Protocol: TCP

· Service: Windows Remote Desktop

· Common Attacks: Brute force attacks, credential stuffing, BlueKeep vulnerability (CVE-2019-0708), RDP man-in-the-middle, ransomware deployment.

· Why Targeted: Provides full graphical desktop access. Widely targeted by ransomware groups for initial access.

Port 5432: PostgreSQL

· Protocol: TCP

· Service: PostgreSQL database

· Common Attacks: Brute force attacks, SQL injection, default credential exploitation, remote code execution vulnerabilities.

· Why Targeted: Increasingly common in modern web applications and cloud deployments.

Port 27017: MongoDB

· Protocol: TCP

· Service: MongoDB (NoSQL database)

· Common Attacks: NoSQL injection, unauthenticated access (default configurations), data theft, ransomware (MongoDB ransom campaigns).

· Why Targeted: Historically, many MongoDB instances were deployed without authentication, leading to massive data breaches.

Port 27017 (Alternative) / 27018-27019: Additional MongoDB Ports

· Protocol: TCP

· Service: MongoDB cluster communication

· Common Attacks: Similar to port 27017, targeting misconfigured cluster instances.

Port 11211: Memcached

· Protocol: UDP (primarily) and TCP

· Service: Distributed memory caching system

· Common Attacks: Memcached DDoS amplification (UDP), information disclosure, data injection.

· Why Targeted: UDP-based Memcached can amplify traffic by factors of 10,000x, making it a favorite for DDoS attacks.

Port 9200 / 9300: Elasticsearch

· Protocol: TCP

· Service: Elasticsearch (search and analytics)

· Common Attacks: Unauthenticated access (default configurations), data exfiltration, remote code execution vulnerabilities.

· Why Targeted: Frequently exposed without authentication, leading to massive data leaks.

Port 5900: VNC (Virtual Network Computing)

· Protocol: TCP

· Service: Remote desktop (cross-platform)

· Common Attacks: Brute force attacks, weak authentication, session hijacking, plaintext credential exposure (if not tunneled).

· Why Targeted: Provides graphical remote access. Often uses weak passwords or no authentication.

Port 8080: HTTP Alternate / Proxy

· Protocol: TCP

· Service: HTTP alternate port (often Tomcat, Jenkins, proxies)

· Common Attacks: Web application vulnerabilities, default credential exploitation (admin/admin), proxy abuse, insecure configurations.

· Why Targeted: Many web applications run on 8080 instead of 80, often with weaker security configurations.

Port 8443: HTTPS Alternate

· Protocol: TCP

· Service: HTTPS alternate port (often Tomcat, JBoss, administration interfaces)

· Common Attacks: Web application vulnerabilities, default credential exploitation, administrative interface exposure.

· Why Targeted: Historically used for botnet C2 communication. Attackers scan for open IRC ports to identify potential C2 infrastructure.

Port 6379: Redis

· Protocol: TCP

· Service: Redis in-memory database

· Common Attacks: Unauthenticated access (default), data theft, remote code execution, SSH key injection (if misconfigured).

· Why Targeted: Redis defaults to no authentication. Exposed instances are frequently exploited for cryptocurrency mining and data breaches.

8. Summary of Port Categories

Category Port Range Description

System Ports (Well-Known) 0 - 1023 Assigned to common services (HTTP, SSH, etc.). Requires root/administrator privileges to bind.

User Ports (Registered) 1024 - 49151 Registered for specific applications (MySQL, RDP, etc.).

Dynamic / Private Ports 49152 - 65535 Used for temporary client-side connections.

9. Security Recommendations

For Port Exposure:

· Close all unnecessary ports. Only expose what is absolutely required.

· Use firewall rules to restrict access to trusted IP addresses only.

· Implement network segmentation to limit exposure of critical services.

· Use VPNs for remote access instead of exposing RDP, SSH, or VNC directly to the internet.

· Enable fail2ban or similar tools to block brute force attempts.

For Database Ports:

· Never expose database ports (3306, 1433, 5432, 27017, 6379) directly to the internet.

· Use strong, unique passwords for all database accounts.

· Disable default accounts (sa, root).

· Keep database software patched and updated.

For Web Ports (80, 443, 8080, 8443):

· Always use HTTPS (443, 8443) instead of HTTP (80, 8080) for production.

· Implement a Web Application Firewall (WAF).

· Regularly scan for and patch web application vulnerabilities.

· Change default credentials on administrative interfaces (Tomcat, Jenkins, etc.).

For Remote Access (22, 3389, 5900):

· Use key-based authentication for SSH instead of passwords.

· Implement multi-factor authentication where possible.

· Change default RDP ports to non-standard ports (security through obscurity is not sufficient alone).

· Use account lockout policies to prevent brute force attacks.

For Email Ports (25, 110, 143, 465, 587, 993, 995):

· Use encrypted versions (SMTPS, IMAPS, POP3S) whenever possible.

· Implement SPF, DKIM, and DMARC to prevent email spoofing.

· Secure mail relays to prevent open relay abuse.

10. Conclusion

Understanding IP addressing, subnetting, transport protocols (TCP and UDP), and common network ports is fundamental to both network administration and security. Attackers routinely scan for open ports and vulnerable services to gain initial access to systems. Proper network design, firewalling, and regular vulnerability assessments are essential to reducing the attack surface